

Email Investigation and Analysis Mini Report

Overview

During the security operations sprint, five reported email threats were analyzed to determine their legitimacy, identify potential risks, and implement appropriate response actions. The investigation focused on email headers, embedded URLs, sender authenticity, and behavioral patterns commonly associated with phishing and malware delivery attacks.

Investigation Summary

The analysis revealed a mix of benign, suspicious, and clearly malicious emails, demonstrating multiple social engineering techniques such as:

- Impersonation of trusted entities (e.g., Adobe, internal teams)
- Use of malicious or compromised URLs
- Delivery of executable payloads
- Use of legitimate infrastructure (e.g., Gmail, Google Drive) to bypass detection

Affiliate Marketing Best Practices

Email Description and Artifacts Collected

Sending Address: jasonconrad099@gmail.com

Subject Line: Affiliate Marketing Best Practices

Recipients: kendrick.lawal@company.com

Sender IP: 209.85.216.49

Reverse DNS: mail-pj1-f49.google.com

Reply-To: jasonconrad099@gmail.com

Date and Time: Sat, 29 Jul 2023 15:46:13 +0100

Full URL:

https://www.authorityhacker.com/successful-affiliate-websites-examples/?referral_code=aef49w31123

Root Domain and IP: authorityhacker.com and 104.26.15.11

Content overview: the email, sent from a Gmail account, shares an article about affiliate marketing and invites the recipient to visit an external website via a link containing a referral code, presenting itself as a helpful team resource.

Security assessment: the email passes SPF, DKIM, and DMARC authentication and has not been flagged by VirusTotal or other security scanners, indicating no known malicious payload or domain reputation issues, though it still originates from an external, non-corporate sender.

Behavior: the message uses a legitimate-looking business topic and a friendly tone to encourage link clicking, with the inclusion of a referral parameter suggesting tracking or affiliate-driven intent rather than direct exploitation.

Verdict: this email is likely benign but unsolicited, with no evidence of malware or phishing, though it should still be treated cautiously as potential marketing or opportunistic outreach rather than a trusted internal communication.

Thus, the email is classed as non malicious

Artifact Analysis (URL)

VirusTotal Reputation – Searching for the full URL and the root domain on VirusTotal shows that it is currently as clean and no threat, therefore it is known not to be malicious in the security community.

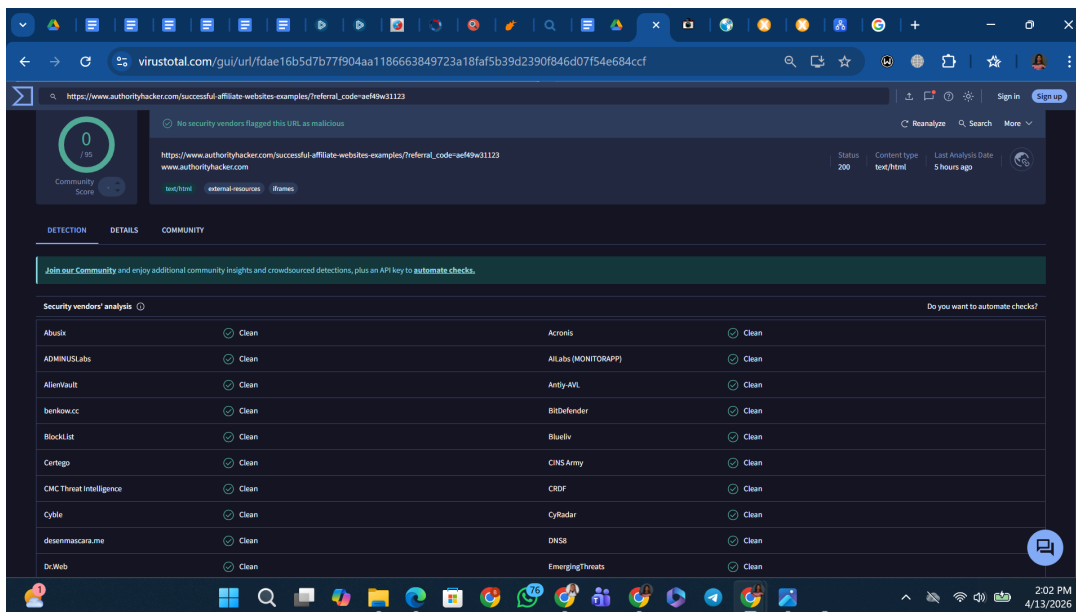


Fig1: Analysis on VirusTotal

URL2PNG and ANY.RUN Analysis – Using URL2PNG and ANY.RUN to view the link destination showed that the site was not hosting a fake website. Looking at the root domain shows that the site does have a genuine

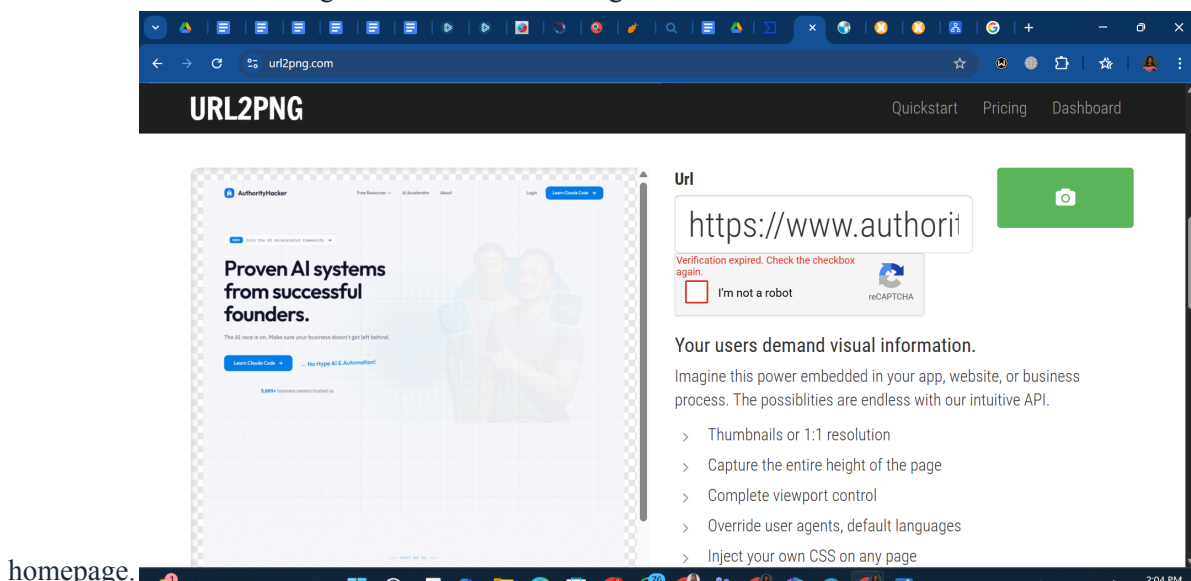


Fig2: Result from URL2PNG

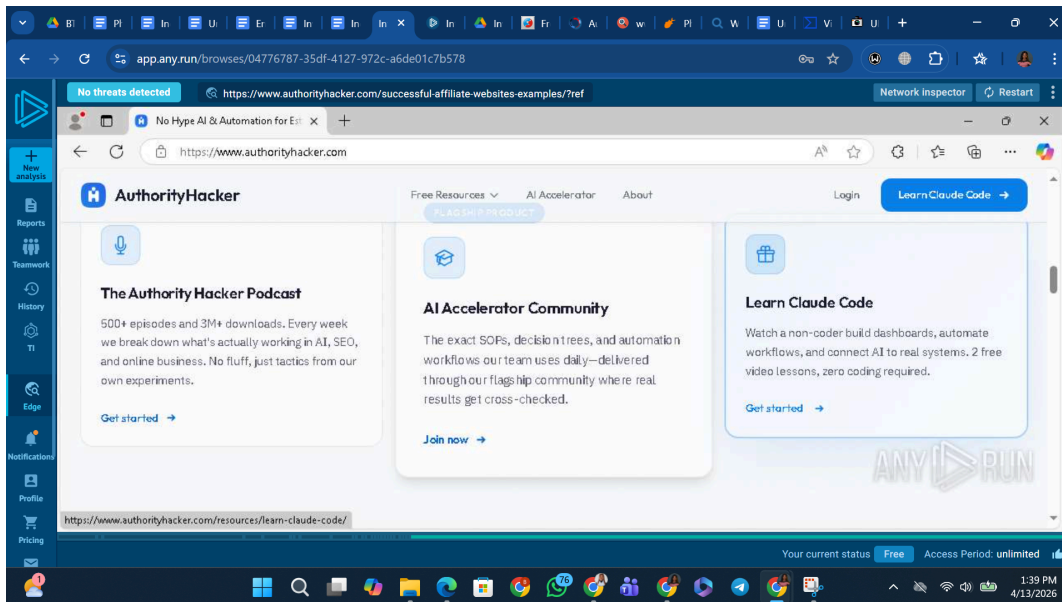


Fig3: ANY.RUN Platform

Hybrid Analysis Scan shows no specific threat.

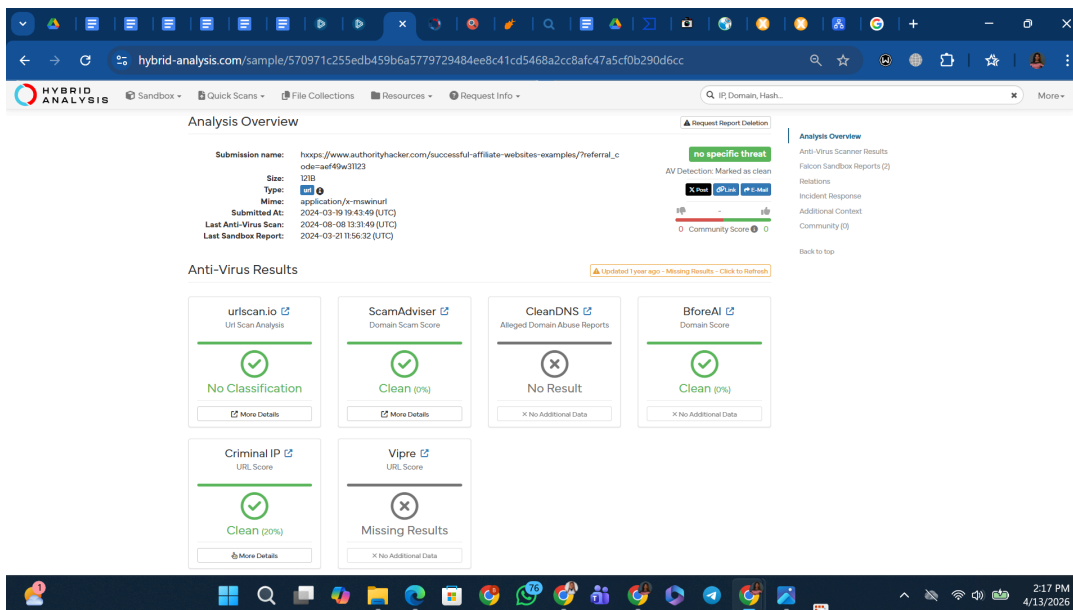


Fig4: Analysis report from HybridAnalysis

A reverse DNS search on the sending server IP 209.85.216.49 shows that this email has definitely originated from mail-pj1-f49.google.com

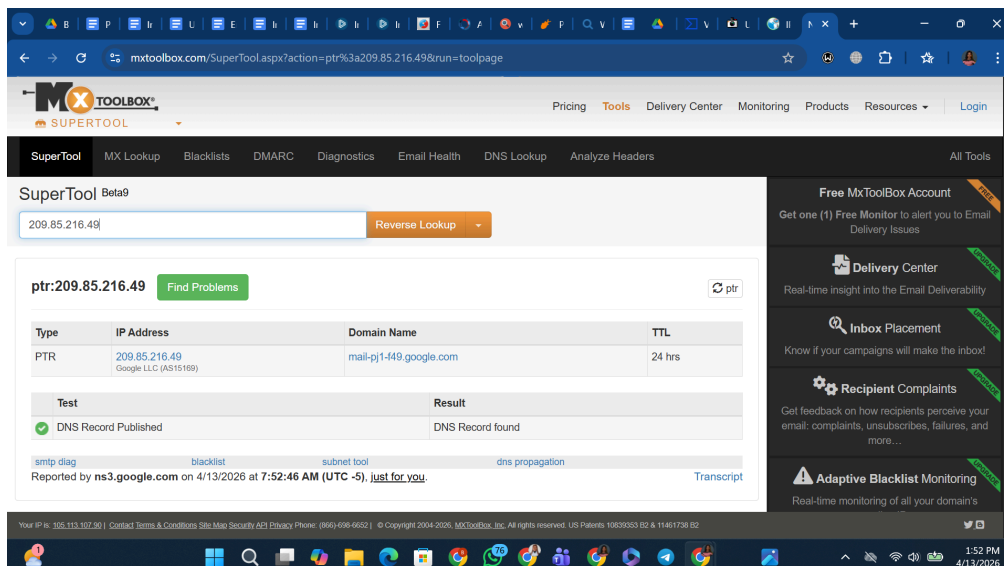


Fig5: Mx ToolBox

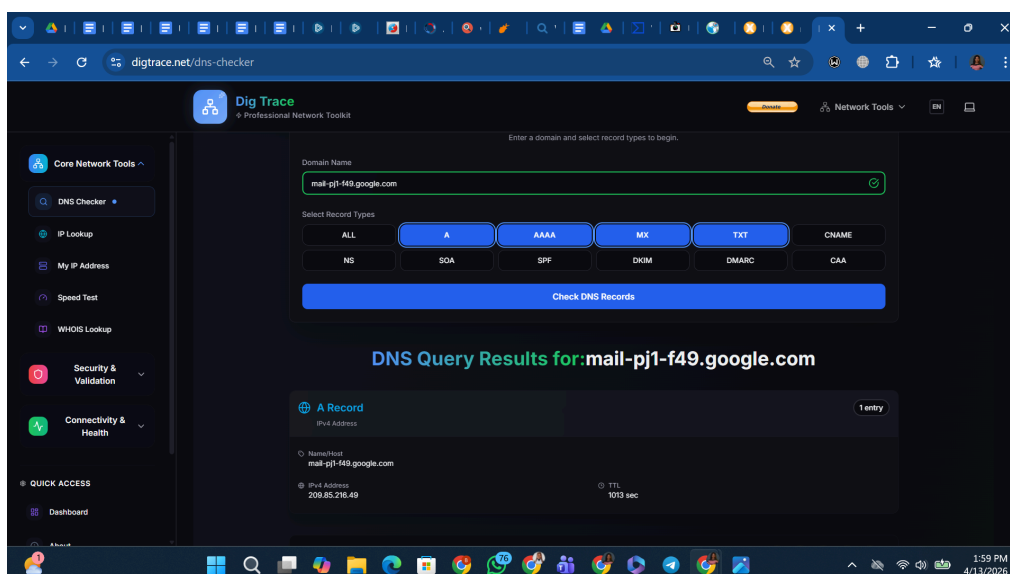


Fig6: The DNS query results from the reverse DNS search

Code Review Request email

Email Description and Artifacts Collected

Sending Address: zelatcol@gmail.com

Subject Line: Code Review Request

Recipients: michelle.jackson@company.com

Sending Server IP: 209.85.214.178

Reverse DNS: mail-pl1-f178.google.com

Reply-To: zelatcol@gmail.com

Date and Time: Sat, 29 Jul 2023 15:22:06 +0100

Full URL: https://wtools.io/paste-code/bOs4

Root Domain: wtools.io and 188.166.15.204

This email is a targeted social engineering attempt leveraging a fake code-review request to lure the recipient into interacting with a malicious external link.

Although the email passes authentication checks and originates from legitimate Gmail infrastructure, the embedded URL has a confirmed malicious reputation and is associated with malware activity.

Thus, the email is classed as malicious/ credential harvester.

Artifact Analysis (URL)

WHOIS, Wanna browser, and Dig Trace Analysis – Performing a WHOIS search on the domain “wtoois.io” shows that the domain was registered 2 years ago, with Namecheap. as the domain registrar. There is no information about the site owner/domain registrant.

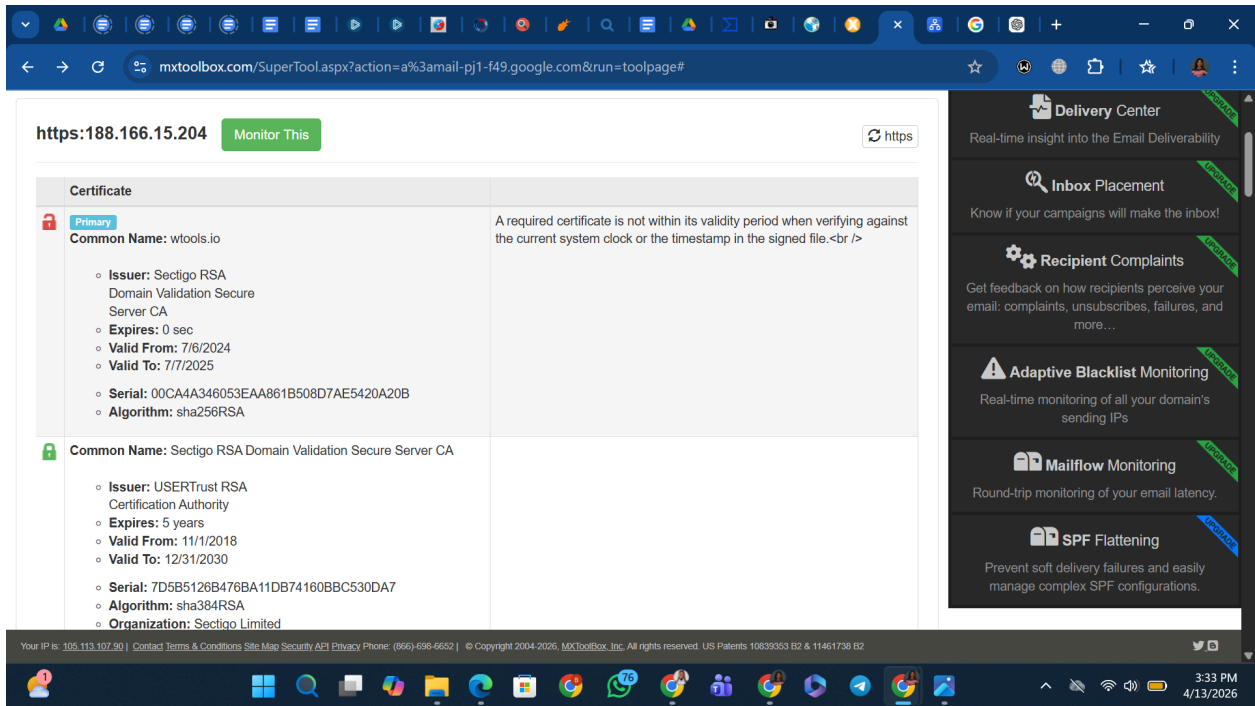


Fig7:Analysis result from Mx ToolBox



Fig8: Information from Wannabrowser

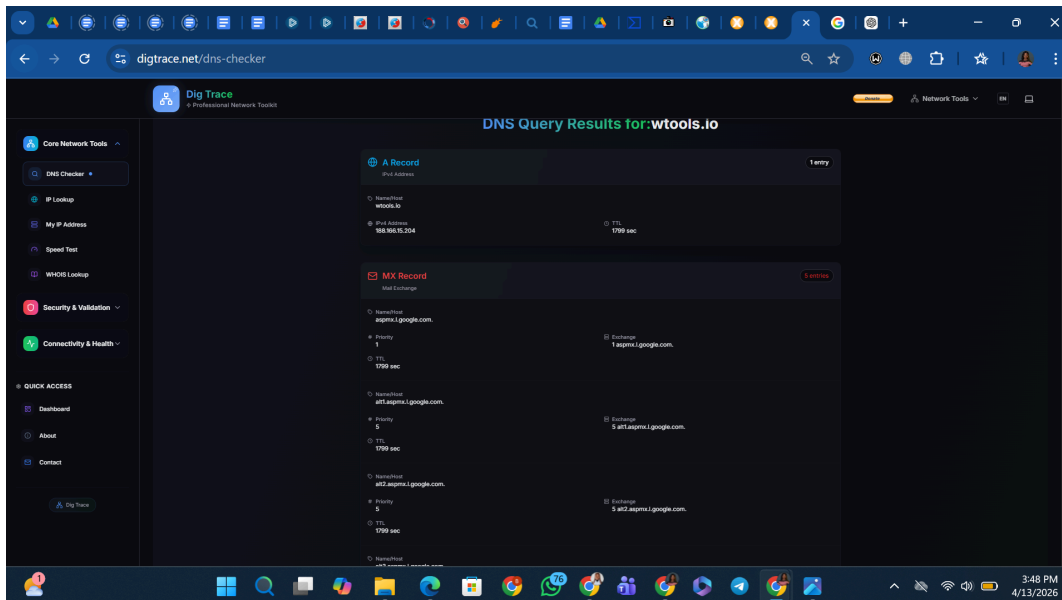


Fig9: DNS query results from DigTrace platform on “wtools.io”

VirusTotal Reputation – Searching for the full URL and the root domain on VirusTotal shows that it is currently flagged as malicious, therefore it is known to be malicious within the security community. The URL was flagged as malicious by 13/95 security vendors, with links to NJRat malware activity.

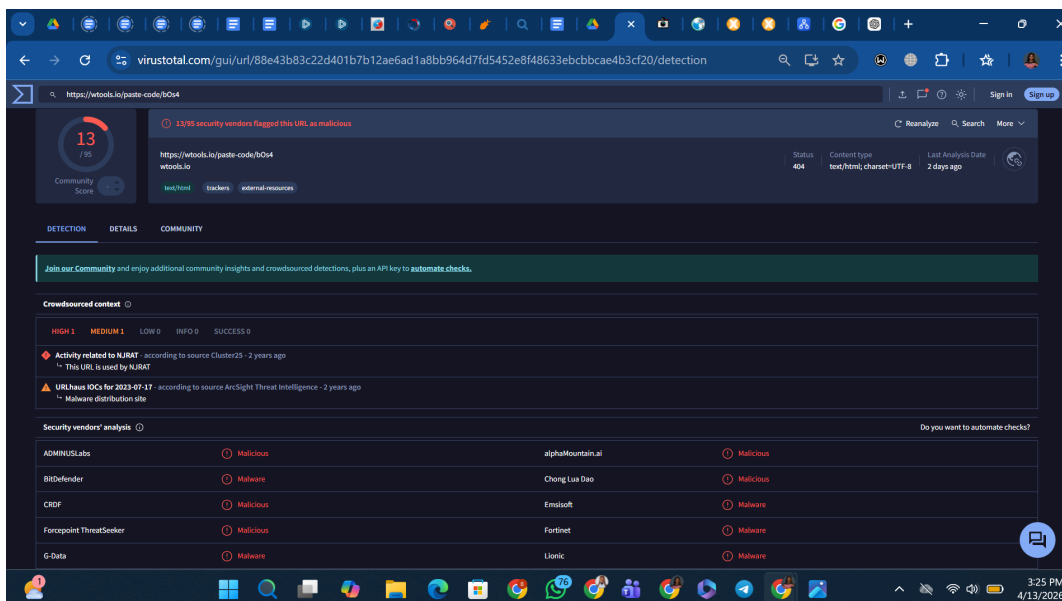


Fig10: Analysis on VirusTotal

ANY.RUN - The page itself returns a 404 (Not Found), It’s a suspicious/malicious URL that likely hosted malware before being taken offline.

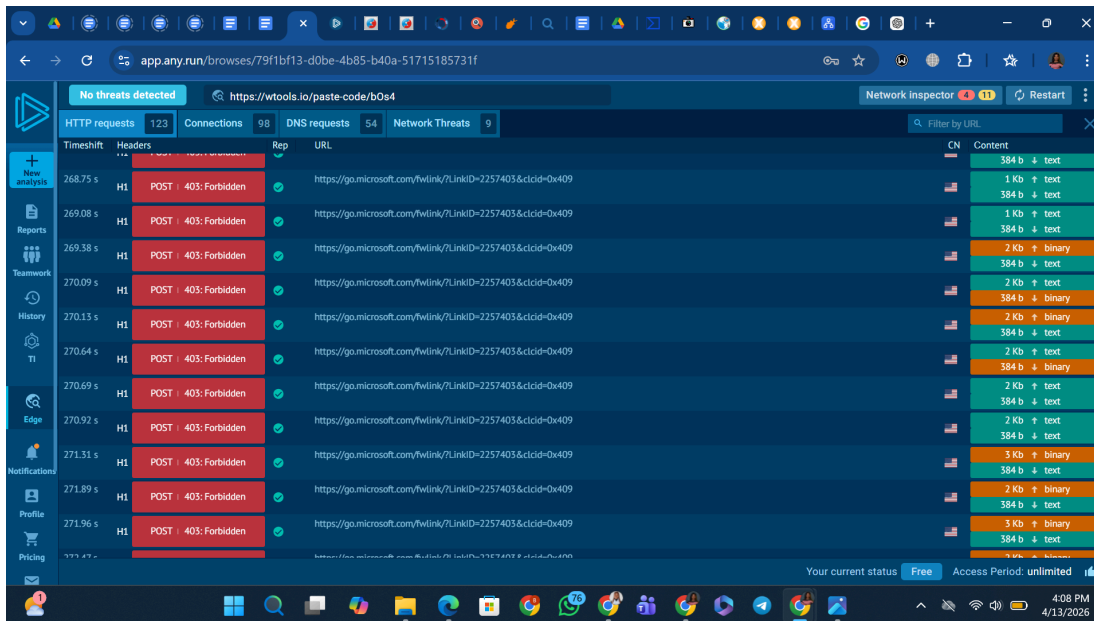


Fig11: Analysis report from ANY.RUN

URL2PNG Analysis – Using URL2PNG to view the link destination showed that the site was hosting a malicious code review site, used to steal codes that are entered for review. Looking at the root domain shows that the site doesn’t exist anymore, a common sight when domains are used for purely malicious operations.

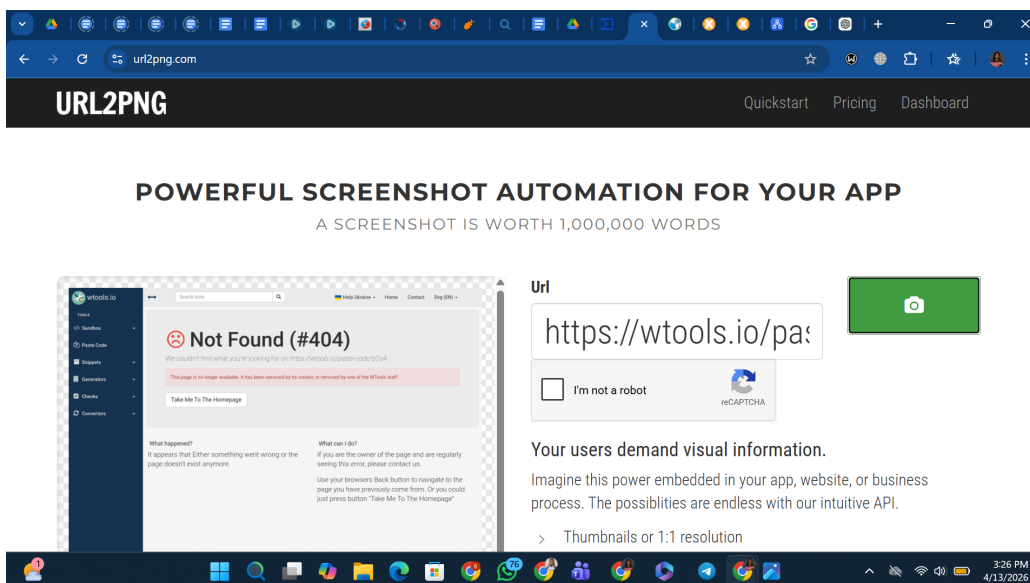


Fig12: "404 error" display from URL2PNG

Hybrid Analysis - The site was flagged malicious including urlscan.io

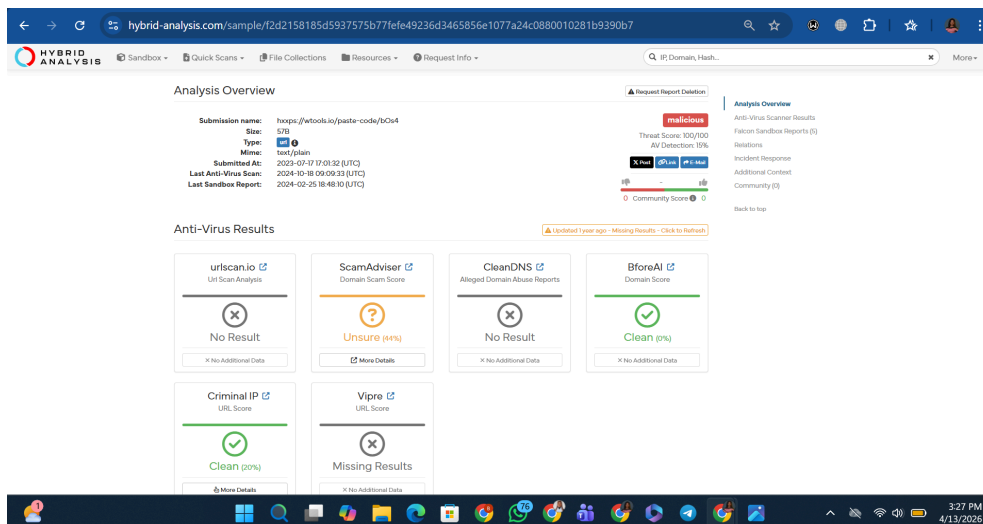


Fig13: Analysis result from HybridAnalysis

The domain is also attempting to appear as a legitimate domain, trying to make the attack more believable to target.

Download Updated Project Files

Email Description and Artifacts Collected

Sending Address: projectdept@kanzalshamsprojectmgt.com

Subject Line: Download Updated Project Files

Recipients: nikefury@company.com

Sending Server IP: 209.85.216.41

Reverse DNS: mail-pj1-f41.google.com

Reply-To: projectdept@kanzalshamsprojectmgt.com

Date and Time: Sat, 29 Jul 2023 15:37:34 +0100

Full URL: <https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y>

Content overview: the email, sent from an external Gmail account but displaying a “Project Management Office” identity, claims that requested project files are ready and provides a direct download link hosted on Google Drive.

Security assessment: although SPF, DKIM, and DMARC all pass and the message has a low spam confidence score, there is a clear mismatch between the display name and the actual sender domain, combined with the use of a generic Gmail relay and a Google Drive download link, both common indicators of potential phishing or malware delivery.

Behavior: the email uses a straightforward, task-oriented message to create urgency and legitimacy, encouraging the recipient to download files via a direct link, which could lead to malicious payload delivery or credential harvesting through trusted cloud infrastructure.

Verdict: this is a high-risk suspicious email, likely a phishing or malware delivery attempt leveraging Google Drive to bypass security controls, and should not be interacted with outside of a controlled sandbox environment.

Thus, the email is classed as malicious

Artifact Analysis (URL)

VirusTotal Reputation and ANY.RUN – Searching for the full URL and the root domain on VirusTotal shows that it is currently flagged as malicious, therefore it is known to be malicious within the security community.

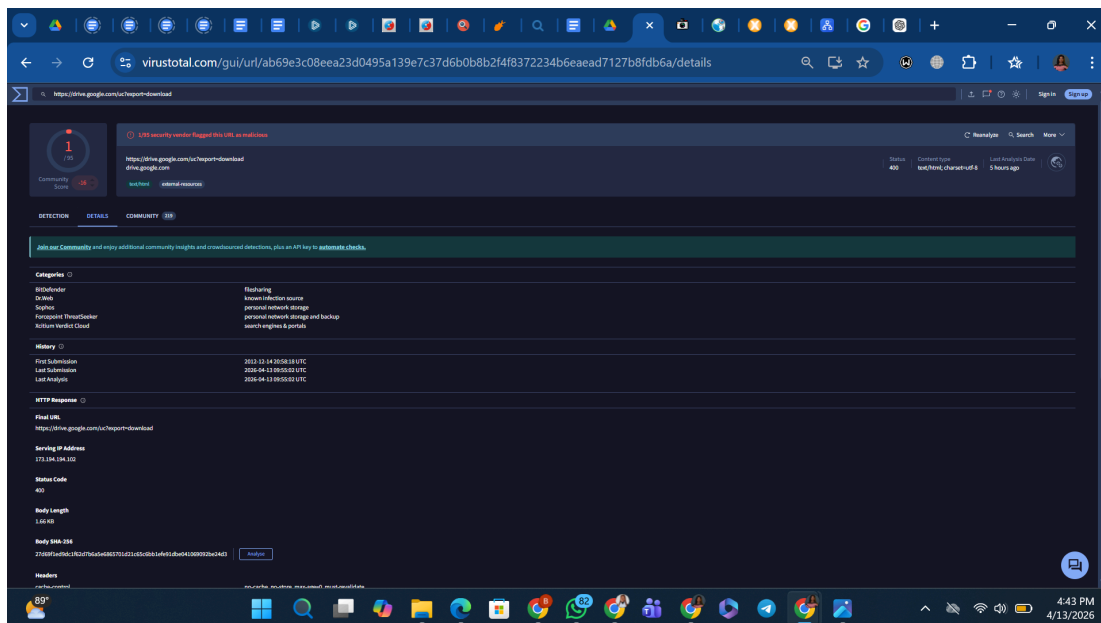


Fig14: Analysis on VirusTotal

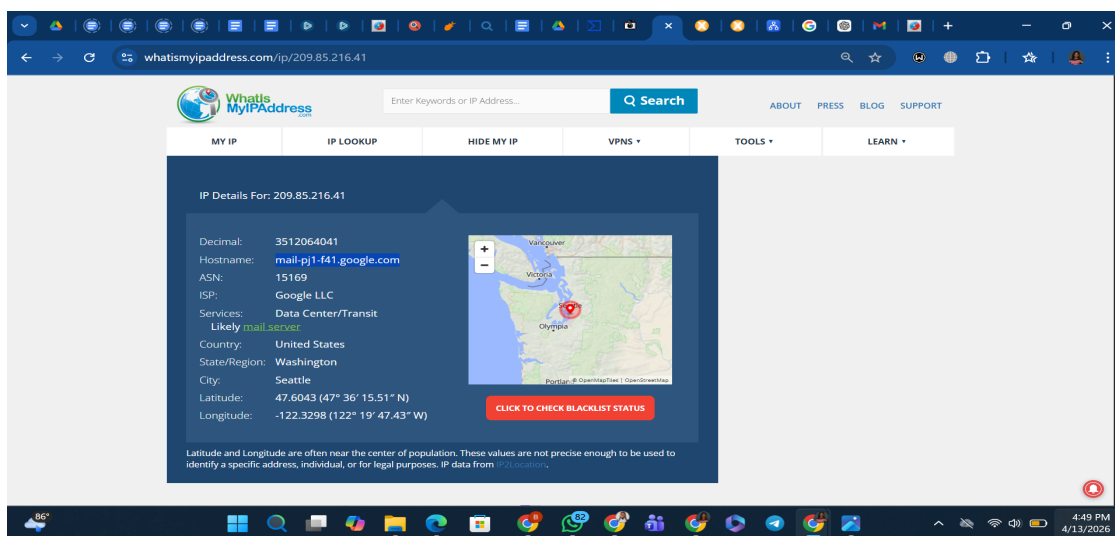


Fig15: Hostname result from whatsmyipaddress platform

Important Adobe Update

Email Description and Artifacts Collected

Sending Address: alfredegov@gmail.com

Subject Line: Important Adobe Update

Recipients: lily.tunechy@company.com

Sending Server IP: 209.85.215.170

Reverse DNS: mail-pj1-f41.google.com

Reply-To: alfredegov@gmail.com

Date and Time: Sat, 29 Jul 2023 15:54:42 +0100

Full URL: http://vml1159541.contaboserver.net/payload.exe

Root Domain and IP: vml1159541.contaboserver.net and 209.145.51.44

Content overview: the email, sent from a Gmail account but impersonating an “Adobe Support Team,” claims an urgent software update is required and instructs the recipient to click a link to update Adobe software.

Security assessment: despite passing SPF, DKIM, and DMARC, the email exhibits multiple high-risk indicators including sender spoofing (Gmail vs. Adobe), mismatched and deceptive URLs (displaying an Adobe update link but pointing to unrelated domains), and a direct link to a downloadable .exe file hosted on a non-trusted server, along with a higher spam confidence level (SCL: 5).

Behavior: the message uses urgency and authority (software security update) to pressure the user into clicking a link, which redirects to a malicious executable payload, a common tactic for malware delivery and initial system compromise.

Verdict: this is a clear phishing and malware delivery attempt, leveraging brand impersonation and deceptive links to trick users into downloading a malicious executable, and should be treated as highly dangerous.

Thus, the email is classed as malicious/ credential harvester.

Artifact Analysis (URL)

WHOIS Analysis – Performing a WHOIS search on the domain “vml1159541.contaboserver.net” shows that the domain was registered 9 years ago, 2017-03-05 07:28:42+00:00 , with RegistryGate GmbH as the domain registrar.

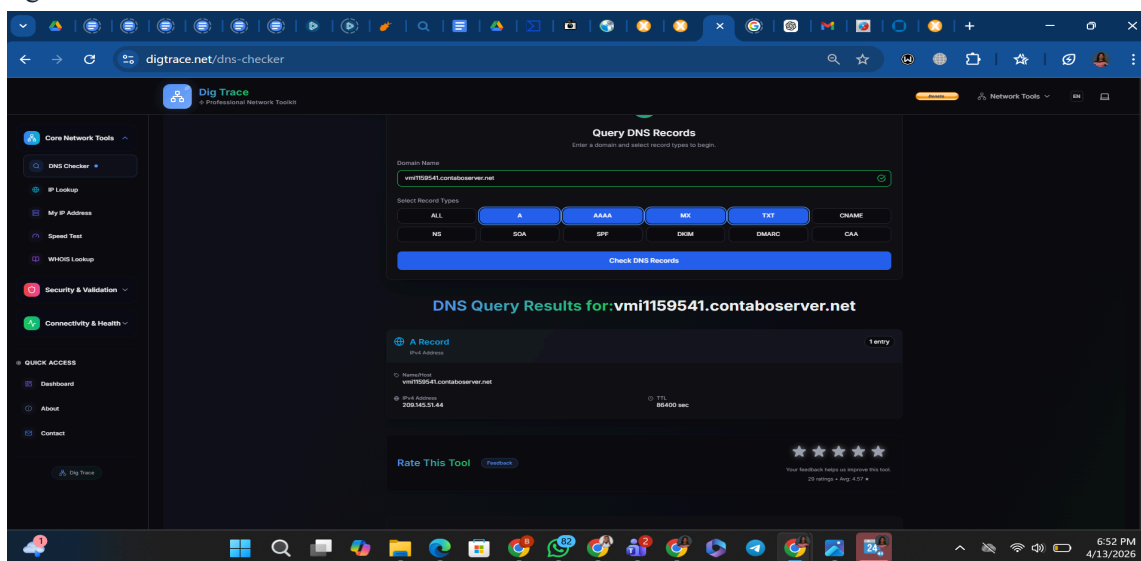
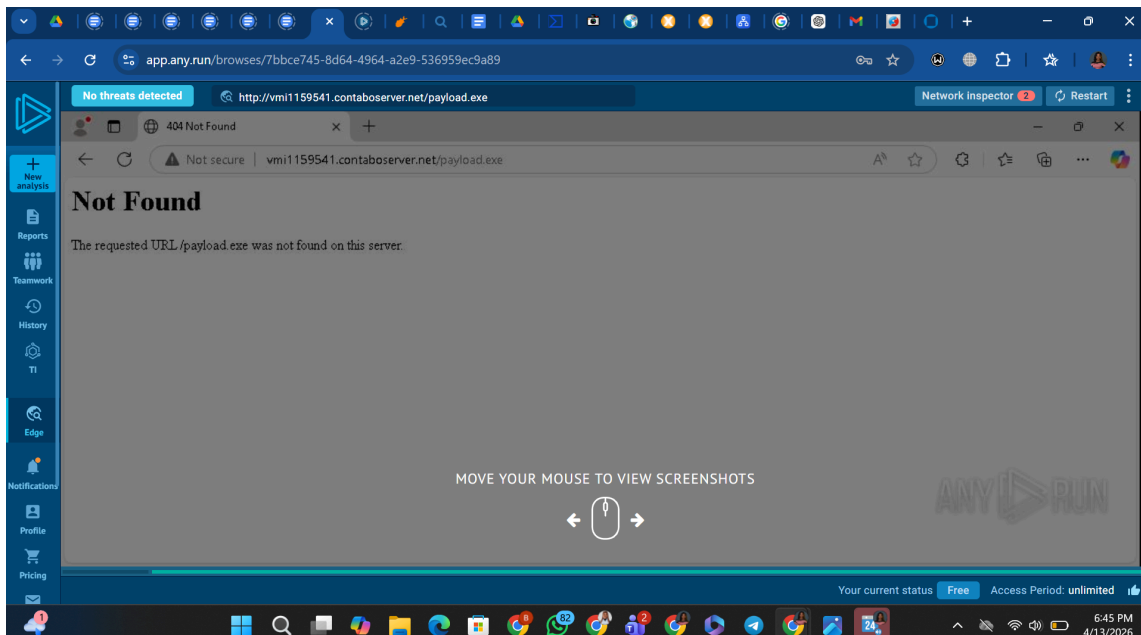
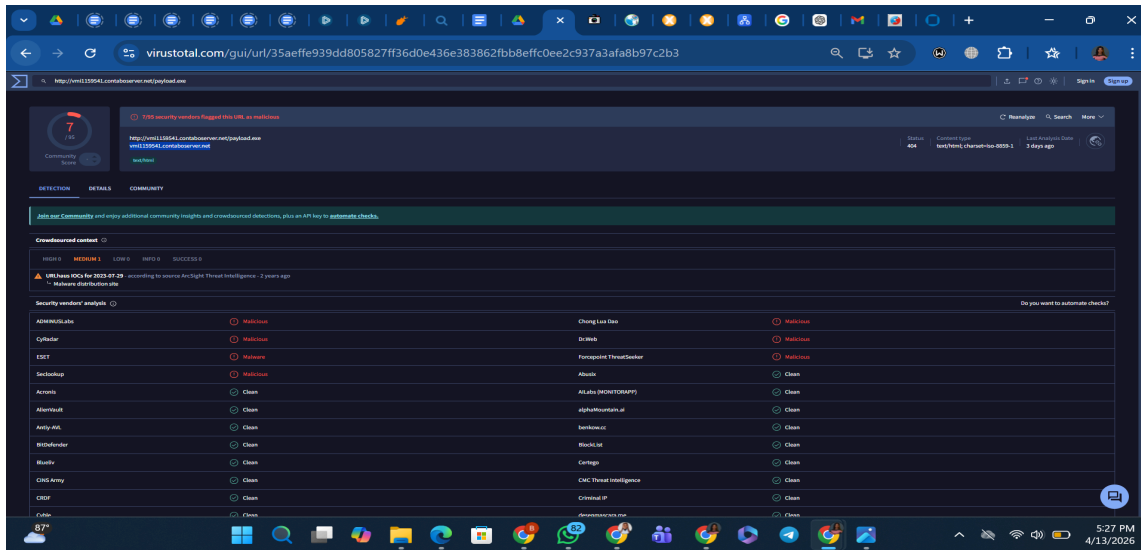
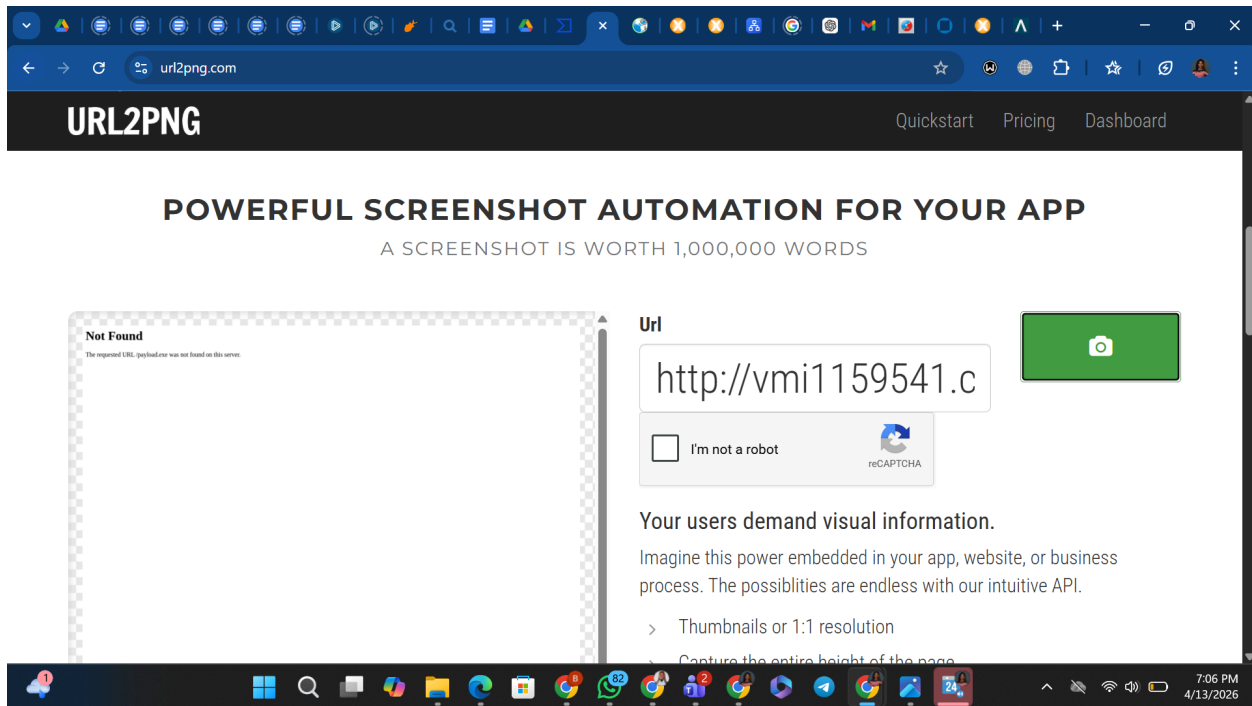


Fig16: DNS query result from digtrace

VirusTotal Reputation – Searching for the full URL and the root domain on VirusTotal shows that it is currently flagged as malicious, therefore it is known to be malicious within the security community.



URL2PNG Analysis – Using URL2PNG to view the link destination showed that the site was hosting a fake British Airways login portal, used to steal any credentials that are entered. Looking at the root domain shows that the site doesn't have a genuine homepage, a common sight when domains are used for purely malicious operations.



The domain is also attempting to typo squat or appear as a legitimate domain, trying to make the attack more believable to target.

Team Building Activity

Email Description and Artifacts Collected

Sending Address: alfredegov@gmail.com

Subject Line: Team Building Activity

Recipients: shina.kagawa@company.com

Sending Server IP: 209.85.210.182

Reverse DNS: mail-pf1-f182.google.com

Reply-To: alfredegov@gmail.com

Date and Time: Sat, 29 Jul 2023 16:27:56 +0100

Full URL: <http://theannoyingsite.com/>

Root Domain and IP: theannoyingsite.com and 209.145.51.44

Content overview: the email, sent from a Gmail account posing as a casual team message, invites the recipient to visit theannoyingsite.com under the guise of a fun team-building activity, but analysis shows it is a low-sophistication social engineering attempt using a suspicious link despite passing standard email authentication checks.

Security Assessment

External sender using generic Gmail (not corporate) with an unsolicited link presented as “fun activity.” Link points to a known suspicious/abusive site. There is no real business context or personalization

Behavior: Uses a casual, social-engineering style lure to prompt users to click a non-business-related external link (“theannoyingsite.com”), which is unrelated to corporate activities.

Verdict: Likely suspicious/phishing-adjacent, while not overtly malicious in headers, the unsolicited external link and irrelevant context make it unsafe to trust or click.

Artifact Analysis (URL)

WHOIS Analysis – Performing a WHOIS search on the domain “theannoyingsite.com” shows that the domain was registered 9 years ago, with Namecheap, Inc. as the domain registrar.

The screenshot shows the Dig Trace website interface. The main content area displays the WHOIS Lookup Results for the domain theannoyingsite.com. The results are organized into a grid of key-value pairs.

Domain Name:	Registrar:	Creation Date:
theannoyingsite.com	NAMECHEAP INC	2017-12-01 07:28:29+00:00
Updated Date:	Expiration Date:	Registrant Name:
2024-08-18 03:43:43+00:00	2033-12-01 07:28:29+00:00	Redacted for Privacy
Registrant Organization:	Registrant Country:	Registrant State/Province:
Privacy service provided by Withheld for Privacy ehf	IS	Capital Region
Registrant City:	Registrant Email:	Name Server:
Reykjavik	abuse@namecheap.com	NS1.LINKDE.COM NS2.LINKDE.COM NS3.LINKDE.COM
DNSSEC:	Status:	
unsigned	clientTransferProhibited https://icann.org/epp/transferProhibited	

Below the results, there are sections for Popular Searches (google.com, yahoo.com, etc.) and a Rate This Tool section with a feedback link.

VirusTotal Reputation – Searching for the full URL and the root domain on VirusTotal shows that it is currently flagged as malicious, therefore it is known to be malicious within the security community. 13 / 95 security vendors flagged it as malicious

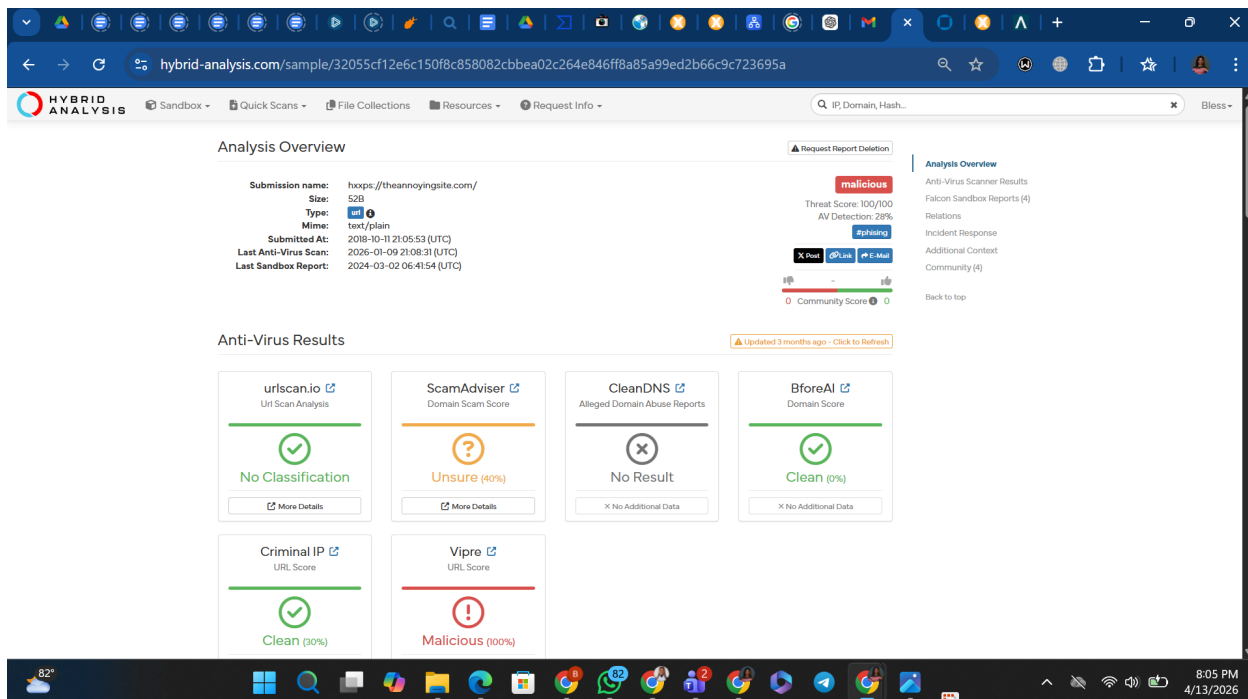
The screenshot shows the VirusTotal analysis page for the URL http://theannoyingsite.com/. The page displays a summary of the analysis, including the URL, status, and a table of security vendors' analysis results.

Summary:

- URL: http://theannoyingsite.com/
- Status: 200
- Content Type: text/html; charset=utf-8
- Last Analysis Date: 2 hours ago

Security vendors' analysis table:

Vendor	Result	Vendor	Result	Vendor	Result
ADW@Labs	Malicious	alphaMountain.ai	Phishing		
BitDefender	Malware	Chong-Lua-Dao	Malicious		
Cybereason	Malicious	CyRadar	Malware		
Fortinet	Malware	G-Dat	Malware		
Kaspersky	Malware	Look	Malware		
Sectiohub	Malicious	WIPRE	Malware		
Webroot	Malicious	ESET	Suspicious		
Abusix	Clean	Acronis	Clean		
AL Labs (MONITORAPP)	Clean	AlamWulf	Clean		
Antiy-AVL	Clean	benkow.cc	Clean		
BlackLot	Clean	BlueV	Clean		
Certiigo	Clean	CMS Army	Clean		
CNC Threat Intelligence	Clean	Cyber	Clean		
dynamilis.com	Clean	DNIS	Clean		
Dr.Web	Clean	EmergingThreats	Clean		



ANY.RUN Analysis showed that the site is triggering multiple annoying/malicious behaviors, such as:

Clipboard access request (“see text and images copied to clipboard”) privacy risk

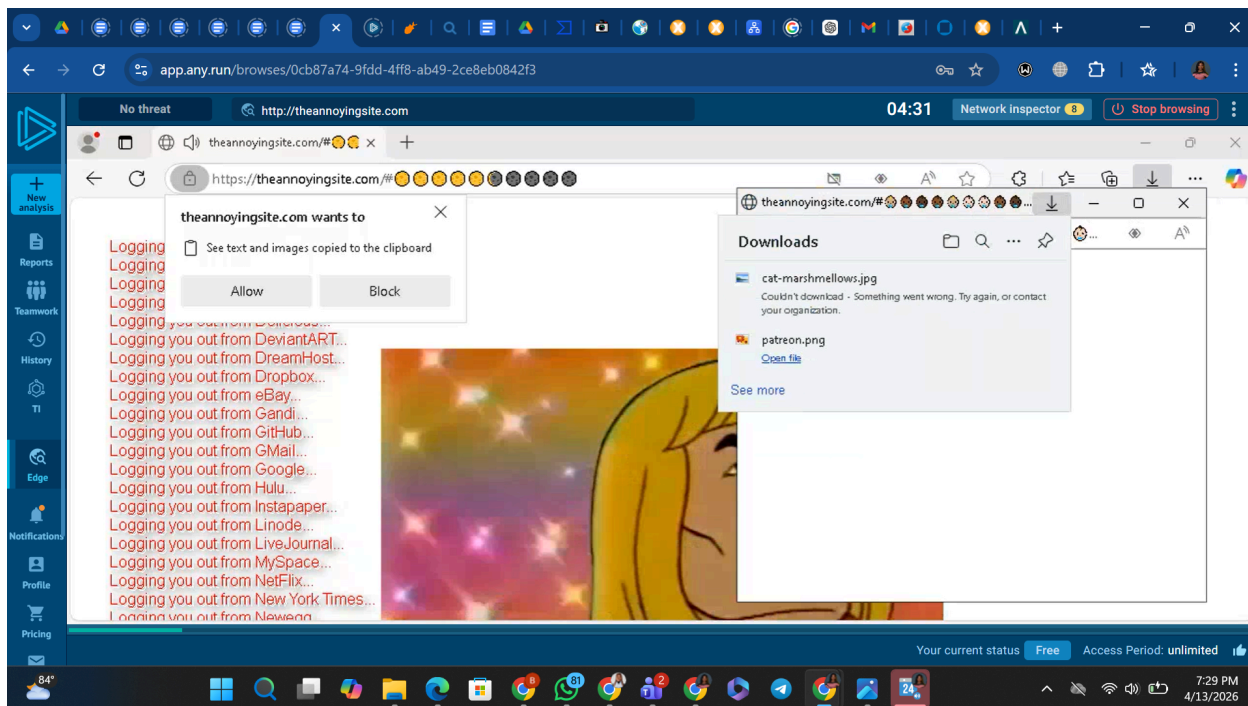
Attempted downloads (e.g., cat-marshmallows.jpg) → often used as a delivery vector

Repeated actions like:

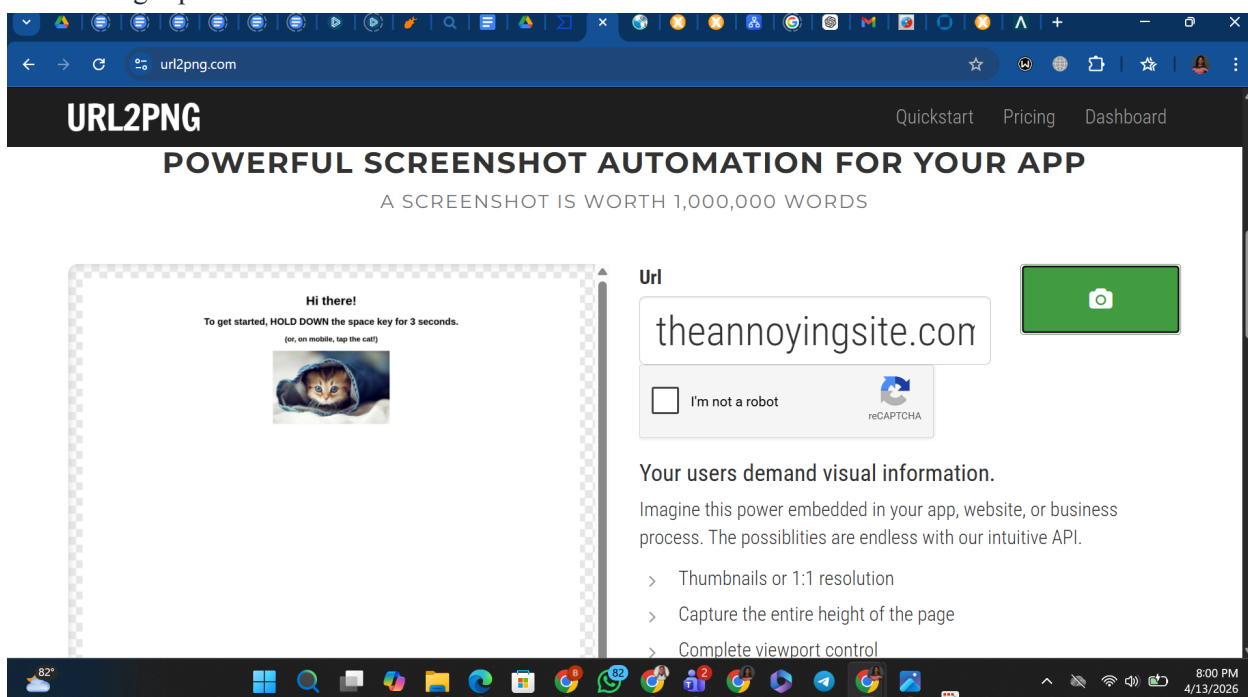
“Logging you out from Google, GitHub, Dropbox...”

→ This is likely simulated or using logout endpoints

Popups, tabs, and UI spam



URL2PNG Analysis – Using URL2PNG to view the link destination showed that the site was hosting a different login portal.



Response actions (containment and eradication)

1. Requesting an email gateway block for the sending addresses for suspicious emails

When a domain has been recognized as malicious, there is no business justification for any employees needing to access this site. As it has a malicious reputation on VirusTotal, and analysis has shown that it is hosting a

credential harvester, the entire domain can be blocked on the web proxy, preventing employees from connecting to the site. This will also make future phishing attacks using this same domain ineffective.

User Awareness and Training

Employee Training: Regularly train employees to recognize phishing attempts, such as suspicious links, urgent requests, and attachments from unknown sources. Phishing awareness campaigns can make users less likely to fall for deceptive emails.

Simulated Phishing Tests: Conduct phishing simulations to test and improve employee vigilance. This helps in assessing their readiness and reinforcing training on identifying phishing tactics.

Email Filtering and Web Protection

Spam Filters: Configure email filters to block malicious emails before they reach users' inboxes. These filters can detect known malicious IPs, attachments, and keywords commonly associated with phishing.

URL Filtering and Blocking: Implement tools that block access to known malicious websites. Many phishing attacks rely on redirecting users to fake websites, so URL filtering can prevent employees from accessing these sites.

Endpoint Protection and Antivirus Software

Antivirus and Anti-malware: Install and keep updated antivirus and anti-malware solutions on all endpoints to detect and remove malicious attachments or ransomware.

Endpoint Detection and Response (EDR): Use EDR solutions that can quickly detect, isolate, and remediate ransomware infections, particularly as they spread within a network.

Network Segmentation and Access Control

Network Segmentation: Divide the network into segments to prevent the spread of ransomware from one system to another. By limiting lateral movement, you reduce the risk of widespread ransomware impact.

Access Controls: Implement the principle of least privilege, ensuring that users have only the minimum access needed to perform their job functions. Restrict access to sensitive data and limit permissions for installing new software.

Multi-Factor Authentication (MFA)

MFA for Critical Accounts: Require MFA for accessing email, VPNs, and other sensitive applications. This reduces the chances of a successful phishing attack even if credentials are compromised.

Regular Backups and Data Recovery Plans

Frequent Backups: Implement regular, automated backups of critical data and store them in a secure, isolated environment. Ransomware often targets backup files, so keeping offline or cloud-based backups is vital.

Tested Recovery Plans: Ensure data recovery plans are tested regularly to verify that backups can restore critical data quickly in case of an attack.

Security Patches and Software Updates

Patch Management: Keep all software, operating systems, and applications up to date. Ransomware often exploits known vulnerabilities, so timely updates can prevent attacks by closing security gaps.

Behavioral Analysis and Anomaly Detection

Network Monitoring: Use intrusion detection systems (IDS) and anomaly detection to identify unusual activity, such as unexpected file encryption or network traffic to unknown IP addresses.

Email Analysis: Leverage machine learning tools that can analyze email patterns and detect potential phishing attacks based on unusual patterns.

Incident Response and Threat Intelligence

Defined Incident Response Plan: Develop and test a clear incident response plan for phishing and ransomware attacks. This includes isolating affected systems, notifying relevant teams, and conducting root cause analysis.

Threat Intelligence Feeds: Integrate threat intelligence to stay updated on new phishing tactics and ransomware variants. This information can be used to preemptively block known threats.